CYBERSECURITY RISK SUMMARY MATRIX	***NIST SP 800-61 Rev. 2** (Computer Security Incident Handling Guide)* does not use generic "severity levels." Instead, it categorizes and prioritizes security incidents using **three precise metrics**:	
This document provides a comprehensive risk assessment summary mapping potential threat categories against likelihood, impact, and recoverability metrics for a technology company.		
	Functional Impact: *The effect on the organization's ability to execute business operations and provide services (None, Low, Medium, High).*	
DOCUMENT OVERVIEW & METHODOLOGY		
Data Sources & Industry Benchmarks	**Information** Impact: *The nature of the compromise to sensitive data (None, Privacy Breach, Proprietary Information Breach, Integrity Loss).*	
The likelihood and threat assessments in this matrix are derived from empirical industry benchmarks, including the Verizon Data Breach Investigations Report (DBIR), IBM Cost of a Data Breach Report, and CISA Threat Trends.		
Framework Integration	**Recoverability** Effort: *The time and resources required to remediate the incident (Regular, Supplemented, Extended, Not Recoverable).*	
This matrix integrates NIST SP 800-61 Rev. 2 (Computer Security Incident Handling Guide) for incident response impact metrics (Functional Impact, Information Impact, and Recoverability Effort) alongside NIST SP 800-30 and ISO/IEC 27005 principles for threat likelihood and risk analysis.		
Importance in Risk Management		
This matrix acts as an essential decision-making tool for security leadership and risk managers. It enables organizations to prioritize security controls based on real-world threat probability, allocate budget effectively, establish clear incident response triage protocols, and communicate technical risks clearly to executive stakeholders.		

Threat Category	Likelihood	Functional Impact
User Mistakes	Extremely High	Low to Medium

Sample-Anna Iris

Malware (Ransomware, Trojans)	High to Very High	High
External Attackers	High to Very High	Medium to High
Internet / ISP Outages	Moderate to High	Medium to High
Location-Wide Power Outages	Moderate to High (Region-dependent)	Low to Medium
Equipment Failure	High (Component) / Low (Outage)	None to Low (With HA)
Malicious Insiders	Low to Moderate	Low to Medium
Natural Disasters	Very Low to Low (Site-dependent)	High (Single Site)

secondary cloud region.

Threat Category	Likelihood	Functional Impact
User Mistakes		
Malware (Ransomware, Trojans)		
External Attackers		
Internet / ISP Outages		

Sample-Ama Uris

Location-Wide Power Outages		
Equipment Failure		
Malicious Insiders		
Natural Disasters		

Sample-Ama Uris

High Risk Tolerance ————> Accepts "Extended" or "Not Recoverable" outcomes (Low pre-incident investment in redundancy/backups) Low Risk Tolerance ————> Tolerates only "Regular" or "Supplemented" effort (High pre-incident investment in Instant Failover, HA, Immutable Backups)			

Information Impact	Recoverability Effort	Concrete Tech Company Example	Risk Tolerance
None to Privacy / Proprietary Breach	Regular	A developer commits API keys to a public GitHub repo; keys are revoked and rotated using standard procedures.	Low

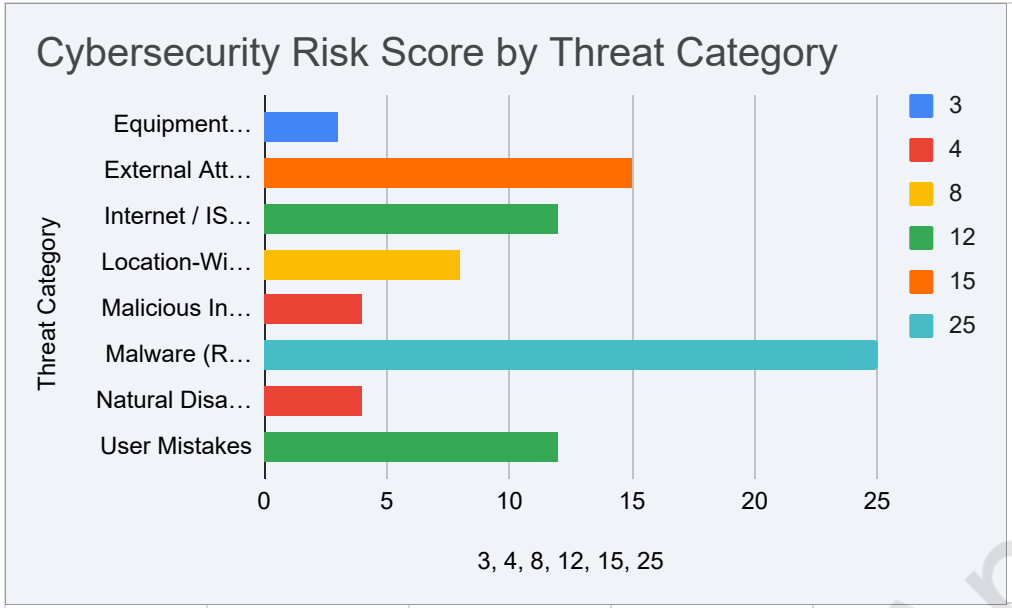
Sample-Ama Uris

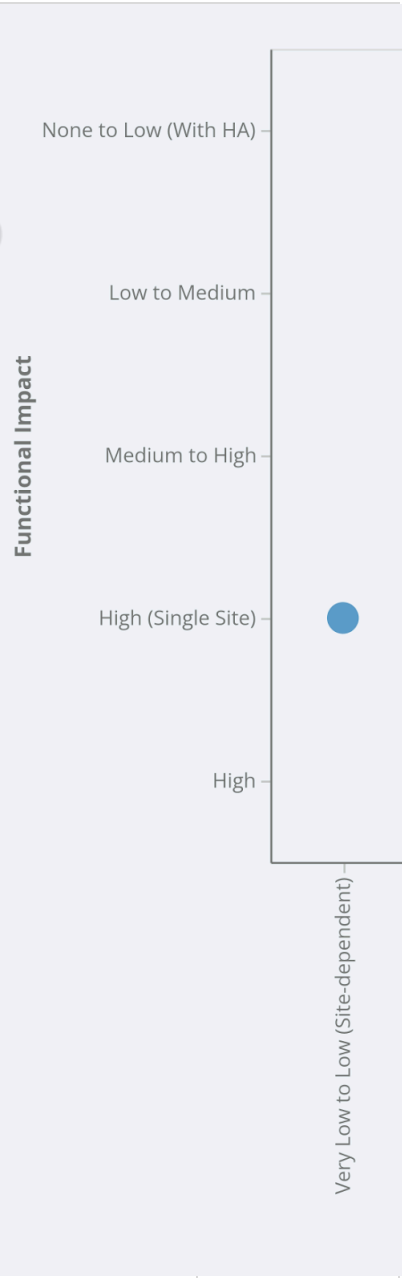
Privacy / Proprietary Breach & Integrity Loss	Extended to Not Recoverable	Double-extortion ransomware encrypts production databases and exfiltrates customer PII; requires external forensics and deep rebuilds.	High
Proprietary Information Breach	Extended	Threat actors exploit an unpatched VPN edge device to compromise internal networks and steal source code.	High
None	Regular	A primary fiber cut isolates a regional office or drops connectivity to customer APIs until carrier repair.	Low
None	Regular	Utility grid failure forces a local office or data center onto backup UPS/generators until grid restoration.	Low
None	Regular	A storage drive fails in a cloud cluster; RAID redundancy and automatic failover absorb the hit with zero downtime.	Low
Proprietary or Privacy Breach	Extended	A departing engineer downloads customer databases and proprietary algorithms to personal storage.	High
None to Integrity Loss (Physical)	Extended	A severe flood inundates a regional facility, forcing failover to a secondary cloud region.	High

Information Impact	Recoverability Effort	Concrete Tech Company Examp	

Sample-Anna Uris

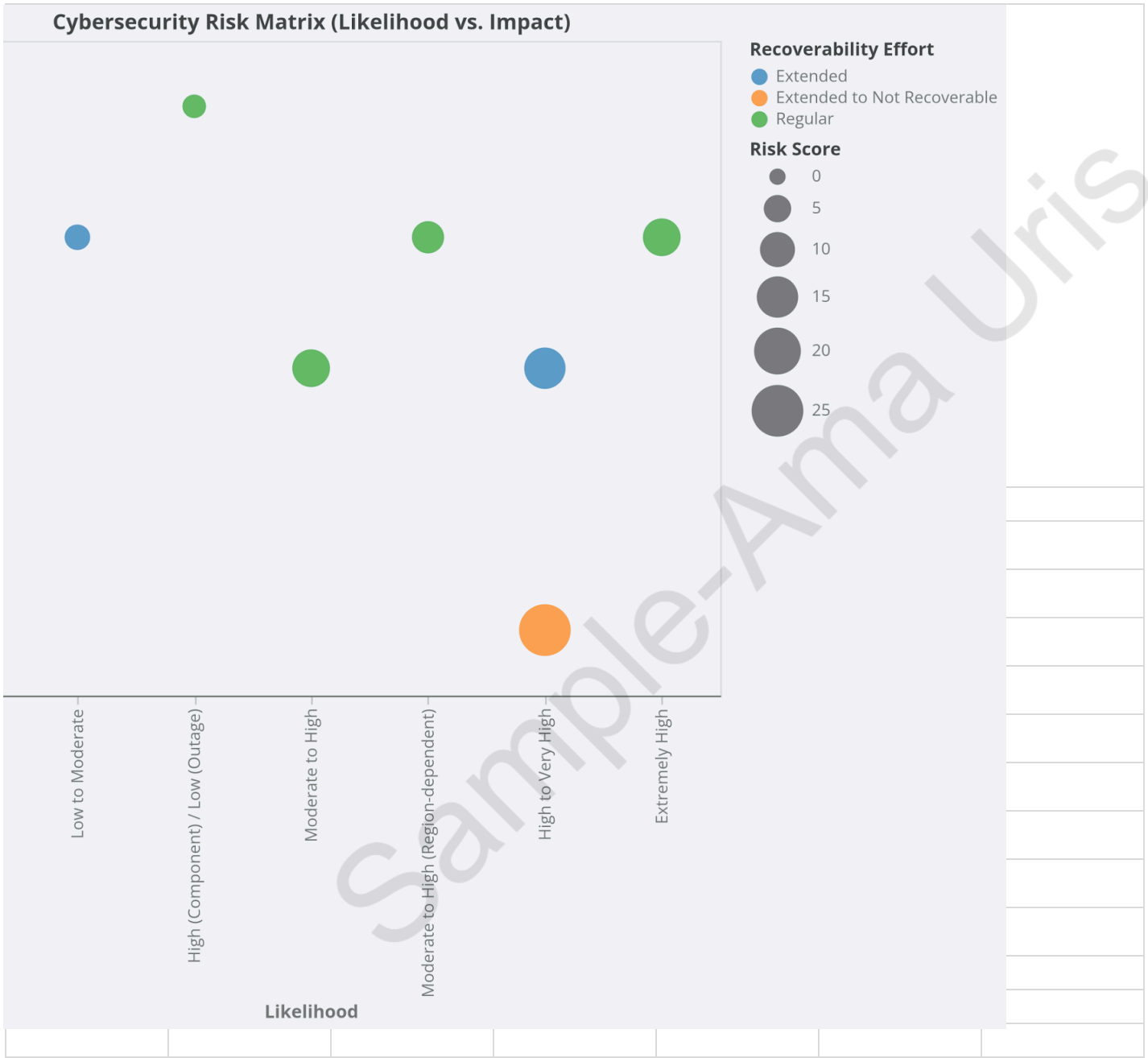
Sample-Ama Uris





Threat Category	# 3	# 4	# 8	# 12	# 15	# 25
Equipment Failu	3	##	##	##	##	##
External Attackers	##	##	##	##	15	##
Internet / ISP Outages	##	##	##	12	##	##
Location-Wide Power Outages	##	##	8	##	##	##
Malicious Insiders	##	4	##	##	##	##
Malware (Ransomware, Trojans)	##	##	##	##	##	25
Natural Disasters	##	4	##	##	##	##
User Mistakes	##	##	##	12	##	##

Sample-Ama Uris



Sample-Ama Uris